

وثيقة استراتيجية

# الأمن السيبراني

منظمي

نوع الوثيقة

وثيقة استراتيجية

القطاع

حكومي

التصنيف

سري

الإصدار

1.0

الحالة

مسودة

تاريخ الإعداد

17 June 2026

## بطاقة ضبط الوثيقة

|                    |  |
|--------------------|--|
|                    |  |
| المنظمة            |  |
| منظمتي             |  |
| القطاع             |  |
| حكومي              |  |
| المجال             |  |
| الأمن السيبراني    |  |
| نوع الوثيقة        |  |
| وثيقة استراتيجية   |  |
| التصنيف            |  |
| سري                |  |
| الإصدار            |  |
| 1.0                |  |
| الحالة             |  |
| مسودة              |  |
| تاريخ الإعداد      |  |
| 17 June 2026       |  |
| أعد بواسطة         |  |
| Mizan GRC Platform |  |

## المحتويات

|    |                                 |
|----|---------------------------------|
| 1  | الملخص التنفيذي                 |
| 2  | النطاق والأطر المرجعية المعتمدة |
| 3  | المنهجية                        |
| 4  | ملخص الوضع الراهن ومستوى النضج  |
| 5  | الرؤية والأهداف الاستراتيجية    |
| 6  | الركائز الاستراتيجية            |
| 7  | البيئة التنظيمية والتحديات      |
| 8  | تحليل الفجوات                   |
| 9  | خارطة الطريق التنفيذية          |
| 10 | مؤشرات الأداء الرئيسية          |
| 11 | تقييم الثقة والمخاطر            |
| 12 | نموذج الحوكمة والمسؤوليات       |
| 13 | مصفوفة تتبع الأطر المرجعية      |
| 14 | الملاحق                         |

هذه الوثيقة سرية ومعدة حصراً للاستخدام الداخلي. جميع التوصيات مبنية على بيانات التشخيص المقدمة.

## الملخص التنفيذي

|                  |                                                                                                                                                                                                                                                                                          |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| الغرض            | الأمن السيبراني المعدة لمنظمتي (القطاع: حكومي)، مبنية على تحليل تشخيصي كامل ومواءمة مع 2 من الأطر المرجعية تقدم هذه الوثيقة استراتيجية المختارة ((NCA ECC, NCA DCC (NCA ECC (Essential Cybersecurity Controls), NCA DCC (Data Cybersecurity Controls)).                                  |
| الأطر المرجعية   | NCA ECC (Essential Cybersecurity Controls) — NCA DCC (Data Cybersecurity Controls)                                                                                                                                                                                                       |
| أبرز الأولويات   | وتعيين CISO؛ تأسيس CSIRT وخطط الاستجابة؛ برنامج إدارة الثغرات؛ تدريب توعوي أمني لجميع الموظفين؛ تطبيق تأسيس إدارة الأمن السيبراني التشفير وإدارة المفاتيح                                                                                                                                |
| أبرز الفجوات     | الأمن السيبراني؛ غياب مركز العمليات الأمنية SOC وأدوات SIEM؛ ضعف إدارة الهوية والوصول IAM / PAM غياب وظيفة CISO وهيكل حوكمة بعد الأمن DLP وخطة رسمية؛ قصور إدارة الثغرات الأمنية وغياب CSIRT؛ غياب فريق الاستجابة للحوادث MFA / والوصول عن                                               |
| أفق التنفيذ      | 24 شهر                                                                                                                                                                                                                                                                                   |
| درجة الثقة       | 78%                                                                                                                                                                                                                                                                                      |
| المخاطر الرئيسية | للحوادث مما يطيل فترة الاحتواء؛ استغلال الثغرات الصفرية في الأنظمة غير المحدثة؛ اختراق البيانات عبر هجمات غياب سياسة موثقة للاستجابة الوعي؛ انتشار برمجيات الفدية عبر الشبكة الداخلية لغياب التجزئة؛ مخاطر الأمن السيبراني لدى الأطراف الثالثة دون تقييم التصيد الاحتيالي نتيجة ضعف رسمي |

## النطاق والأطر المرجعية المعتمدة

NCA ECC (Essential Cybersecurity Controls) (ECC)

يعكس هذا الإطار في الاستراتيجية عبر مجالات: الحوكمة، إدارة الهوية، مركز العمليات الأمنية، الاستجابة للحوادث، إدارة الثغرات.

NCA DCC (Data Cybersecurity Controls) (DCC)

يعكس هذا الإطار في الاستراتيجية عبر مجالات: تصنيف البيانات، التشفير، DLP، البيانات الحساسة، حماية البيانات.

## المنهجية

### المرحلة 1 – تحليل المدخلات التشخيصية

مراجعة منهجية للبيانات التشخيصية المدخلة من المنظمة (القطاع، الحجم، النضج الحالي، الأنظمة، التحديات) وتأكيد جودة المدخلات قبل بدء أي تحليل.

### المرحلة 2 – تحديد نطاق الأطر المرجعية

اعتماد الأطر التالية كنطاق رسمي للتحليل والمواءمة: NCA ECC (Essential Cybersecurity Controls), NCA DCC (Data Cybersecurity Controls), NCA ECC, NCA DCC.

### المرحلة 3 – تحليل تغطية القدرات

مطابقة المدخلات والضوابط القائمة مع عائلات القدرات التي تتطلبها الأطر المختارة (الحوكمة، إدارة الهوية، المراقبة، الاستجابة، الوصول عن بعد، حماية البيانات...).

### المرحلة 4 – تحليل الفجوات وترتيب الأولويات

استخراج الفجوات بين الوضع الحالي ومتطلبات الأطر، وترتيبها وفق الأثر والأولوية والقابلية للمعالجة.

### المرحلة 5 – تصميم خارطة الطريق والمؤشرات

بناء خارطة طريق متعددة الموجات (قصيرة/متوسطة/طويلة المدى) مرتبطة بمؤشرات أداء (KPI) ومؤشرات مخاطر (KRI) قابلة للقياس.

### المرحلة 6 – تقييم المخاطر والثقة

تقدير المخاطر التنفيذية ومخاطر التغيير، وحساب درجة ثقة شاملة في قابلية تنفيذ الاستراتيجية.

### المرحلة 7 – التحقق وبوابات الجودة

اجتياز سلسلة بوابات التحقق: التحقق من المجال، كثافة المحتوى، تغطية الأطر، التدقيق الدلالي، ثم التدقيق النهائي قبل النشر.

## ملخص الوضع الراهن ومستوى النضج

السياق التنظيمي: يفرض الإطار التنظيمي المطبق على منظمتي — وعلى رأسه متطلبات NCA ECC, NCA DCC المعمول بها في قطاع حكومي — التزامات محددة على حوكمة الأمن السيبراني، بما يشمل إثبات تطبيق الضوابط والحوكمة المستمرة وإعداد أدلة التدقيق وفق اللوائح والأنظمة السارية. وتشمل الأطر التنظيمية المختارة الملزمة لمنظمتي: NCA ECC، NCA DCC. إذ تكشف القدرات الأساسية عن فجوات يجب سدها قبل تحقيق أي التزام مستدام.

سياق التهديدات: تشير البيانات العامة لفرق الاستجابة الوطنية خلال آخر دورة تقرير إلى ارتفاع ملحوظ في حوادث اختراق سلاسل الإمداد، والتصيد الموجه، وحملات برامج الفدية — مما يرفع أولوية تحصين ضوابط الأمن السيبراني لدى منظمتي وتسريع النضج التشغيلي في الاستجابة للحوادث.

## الرؤية والأهداف الاستراتيجية

ركيزة استراتيجية تدعم تنفيذ القدرات السيبرانية المطلوبة وفق إطار NCA ECC/DCC.

ركيزة استراتيجية تدعم تنفيذ القدرات السيبرانية المطلوبة وفق إطار NCA ECC/DCC.

ركيزة استراتيجية تدعم تنفيذ القدرات السيبرانية المطلوبة وفق إطار NCA ECC/DCC.

إنشاء إدارة متخصصة للأمن السيبراني وتعيين CISO وتفعيل لجنة الحوكمة ونموذج التشغيل 1.

|                        |                                                                           |
|------------------------|---------------------------------------------------------------------------|
| المستهدف القابل للقياس | إنجاز الهيكل التنظيمي بنسبة 100% وتعيين CISO مؤهل خلال الإطار المحدد      |
| المبرر                 | ضرورة وجود هيكل تنظيمي متخصص لقيادة وإدارة برنامج الأمن السيبراني بفعالية |
| الإطار الزمني          | 6 أشهر                                                                    |

تحقيق الالتزام بضوابط NCA ECC و NCA DCC المختارة 2.

|                        |                                                                                 |
|------------------------|---------------------------------------------------------------------------------|
| المستهدف القابل للقياس | نسبة امتثال لا تقل عن 90% للضوابط الأساسية والدرجة                              |
| المبرر                 | ضمان مواءمة برنامج الأمن السيبراني مع المتطلبات التنظيمية وتقليل فجوات الامتثال |
| الإطار الزمني          | 12 شهرا                                                                         |

نشر منظومة إدارة الهويات والتحكم في الوصول عبر جميع الأنظمة الحيوية 3.

|                        |                                                             |
|------------------------|-------------------------------------------------------------|
| المستهدف القابل للقياس | تطبيق مبدأ الصلاحيات الدنيا على 100% من الحسابات المميزة    |
| المبرر                 | ضعف التحكم في الوصول يشكل نقطة دخول رئيسية للاختراق الداخلي |
| الإطار الزمني          | 12 شهرا                                                     |

تطوير برنامج إدارة الثغرات الأمنية المستمر 4.

|                        |                                                             |
|------------------------|-------------------------------------------------------------|
| المستهدف القابل للقياس | معالجة 95% من الثغرات الحرجة خلال 72 ساعة وفق SLA           |
| المبرر                 | تقليل نوافذ التعرض للهجمات وتعزيز الامتثال لمتطلبات NCA ECC |
| الإطار الزمني          | 12 شهرا                                                     |

إنشاء وتشغيل مركز عمليات الأمن السيبراني SOC/SIEM 5.

|                        |                                                                               |
|------------------------|-------------------------------------------------------------------------------|
| المستهدف القابل للقياس | تشغيل مراقبة أمنية مستمرة 24/7 وتغطية 90% من الأنظمة الحرجة خلال 12 شهرا      |
| المبرر                 | معالجة فجوة الرصد المستمر وتحسين القدرة على الكشف المبكر والاستجابة للتهديدات |
| الإطار الزمني          | 12 شهرا                                                                       |

إنشاء فريق الاستجابة للحوادث السيبرانية مع خطط مختبرة وموثقة 6.

|                        |                                                              |
|------------------------|--------------------------------------------------------------|
| المستهدف القابل للقياس | إجراء 4 تمارين محاكاة سنويا بمعدل إغلاق حوادث لا يقل عن 90%  |
| المبرر                 | غياب فريق استجابة مهيكل يطيل أمد الحوادث ويرفع تكلفة التعافي |
| الإطار الزمني          | 12 شهرا                                                      |

تنفيذ برنامج اختبار الاختراق الدوري لجميع الأنظمة الجوهرية 7.

|                        |                                                                      |
|------------------------|----------------------------------------------------------------------|
| المستهدف القابل للقياس | تغطية 100% من الأنظمة الحيوية بجولتي اختبار سنويا على الأقل          |
| المبرر                 | الاعتماد على ضمانات المورد دون اختبار مستقل يخفي مواطن الضعف الفعلية |
| الإطار الزمني          | 12 شهرا                                                              |

تعزيز حماية البيانات عبر التصنيف والتشفير و DLP 8.

|                        |                                       |
|------------------------|---------------------------------------|
| المستهدف القابل للقياس | حماية 95% من البيانات الحساسة المصنفة |
| المبرر                 | تلبية متطلبات NCA DCC لحماية البيانات |
| الإطار الزمني          | 18 شهر                                |



## الركائز الاستراتيجية

---

## البيئة التنظيمية والتهديدات

السياق التنظيمي: يفرض الإطار التنظيمي المطبق على منظمتي — وعلى رأسه متطلبات NCA ECC, NCA DCC المعمول بها في قطاع حكومي — التزامات محددة على حوكمة الأمن السيبراني، بما يشمل إثبات تطبيق الضوابط والحوكمة المستمرة وإعداد أدلة التدقيق وفق اللوائح والأنظمة السارية. وتشمل الأطر التنظيمية المختارة الملزمة لمنظمتي: NCA ECC، NCA DCC. إذ تكشف القدرات الأساسية عن فجوات يجب سدها قبل تحقيق أي التزام مستدام.

سياق التهديدات: تشير البيانات العامة لفرق الاستجابة الوطنية خلال آخر دورة تقرير إلى ارتفاع ملحوظ في حوادث اختراق سلاسل الإمداد، والتصيد الموجه، وحملات برامج الفدية — مما يرفع أولوية تحصين ضوابط الأمن السيبراني لدى منظمتي وتسريع النضج التشغيلي في الاستجابة للحوادث.

السياق التشغيلي وسياق الأعمال: يترتب على منظمتي موازنة متطلبات التحول الرقمي مع الحفاظ على استمرارية الأعمال والعمليات في قطاع حكومي، وضمان أن تواكب استثمارات الأمن السيبراني وتيرة توسع الخدمات والعمليات دون إحداث فجوات تدقيقية أو ضغط تشغيلي على الكوادر.

| تطبيق الضوابط المرتبطة ومتابعتها | عالية  | عال   | تنظيمي |  |
|----------------------------------|--------|-------|--------|--|
| تطبيق الضوابط المرتبطة ومتابعتها | عالية  | عال   | تهديد  |  |
| تطبيق الضوابط المرتبطة ومتابعتها | متوسطة | متوسط | أعمال  |  |

## تحليل الفجوات

| 1 | وهيكل حوكمة الأمن السيبراني<br>غياب وظيفة CISO               | ولا سياسات معتمدة، ولا لجنة حوكمة مخصصة تربط متطلبات...<br>لا توجد قيادة رسمية للأمن السيبراني، | حرجة   | مفتوحة |
|---|--------------------------------------------------------------|-------------------------------------------------------------------------------------------------|--------|--------|
| 2 | الأمنية SOC وأدوات SIEM<br>غياب مركز العمليات                | مستمرة، مما يعرض البيئة الحكومية لتهديدات غير مكتشفة وفق...<br>لا تمتلك المنظمة قدرة رصد أمني   | حرجة   | مفتوحة |
| 3 | والوصول IAM / PAM / MFA<br>ضعف إدارة الهوية                  | وتعدد عوامل المصادقة، مما يشكل ثغرة أمنية جوهرية في بيئات...<br>غياب التحكم في الوصول المتميز   | عالية  | مفتوحة |
| 4 | للحوادث CSIRT وخطة رسمية<br>غياب فريق الاستجابة              | للحوادث ولا فريق CSIRT معين، مما يزيد من أثر الاختراق وز...<br>لا توجد إجراءات موثقة للاستجابة  | عالية  | مفتوحة |
| 5 | وغياب DLP والوصول عن بعد الآمن<br>قصور إدارة الثغرات الأمنية | أو مسح الثغرات بانتظام، ولا توجد ضوابط لمنع فقدان البيانات...<br>لا تجرى دورات اختبار الاختراق  | متوسطة | مفتوحة |

1

|               |                                                                                                      |
|---------------|------------------------------------------------------------------------------------------------------|
| الإجراء       | تحديد مسمى CISO رسمياً ورفع مقترح التعيين لصاحب الصلاحية مع تحديد نطاق المسؤوليات والتبعية التنظيمية |
| المسؤول       | الإدارة العليا                                                                                       |
| الإطار الزمني | الشهر 1                                                                                              |
| النتائج       | قرار تعيين CISO معتمد                                                                                |

2

|               |                                                                                               |
|---------------|-----------------------------------------------------------------------------------------------|
| الإجراء       | تشكيل لجنة حوكمة الأمن السيبراني وتحديد أعضائها من وحدات الأعمال الرئيسية والقانونية والتقنية |
| المسؤول       | CISO                                                                                          |
| الإطار الزمني | الشهر 2                                                                                       |
| النتائج       | ميثاق لجنة الحوكمة موقع                                                                       |

3

|               |                                                                                            |
|---------------|--------------------------------------------------------------------------------------------|
| الإجراء       | تطوير منظومة السياسات الأمنية الأساسية وآلية مراجعتها السنوية استناداً إلى متطلبات NCA ECC |
| المسؤول       | المسؤول أمن السيبراني e Lead                                                               |
| الإطار الزمني | الشهر 3                                                                                    |
| النتائج       | حزمة سياسات أمنية معتمدة                                                                   |

4

|               |                                                                                                                 |
|---------------|-----------------------------------------------------------------------------------------------------------------|
| الإجراء       | إنشاء إطار إدارة مخاطر الأمن السيبراني وتحديد شبيهة المخاطر التنظيمية وآلية إعداد التقارير الدورية لصاحب القرار |
| المسؤول       | CISO                                                                                                            |
| الإطار الزمني | الشهر 4                                                                                                         |
| النتائج       | سجل مخاطر أمني موثق وتقرير دوري معتمد                                                                           |

5

|         |                                                                                  |
|---------|----------------------------------------------------------------------------------|
| الإجراء | إجراء تقييم امتثال NCA ECC الأولي وتحديد مستوى النضج الراهن وخارطة طريق الارتقاء |
|---------|----------------------------------------------------------------------------------|

|               |                                           |
|---------------|-------------------------------------------|
| المسؤول       | المسؤول أمن السيراني e Lead               |
| الإطار الزمني | الشهر 5                                   |
| النتائج       | تقرير تقييم الامتثال وخارطة طريق الارتقاء |

1

|               |                                                                                                             |
|---------------|-------------------------------------------------------------------------------------------------------------|
| الإجراء       | تشغيل SOC ال مناسب (داخلي أو مدار MSSP) ورفع دراسة الجدوى للإدارة العليا مع متطلبات NCA ECC-1-1 تحديد نموذج |
| المسؤول       | CISO                                                                                                        |
| الإطار الزمني | الشهر 1                                                                                                     |
| النتائج       | قرار نموذج تشغيل SOC معتمد                                                                                  |

2

|               |                                                                       |
|---------------|-----------------------------------------------------------------------|
| الإجراء       | تحديد متطلبات منصة SIEM وتقييم الموردين وإعداد وثيقة المواصفات الفنية |
| المسؤول       | SOC Manager                                                           |
| الإطار الزمني | الشهر 2                                                               |
| النتائج       | وثيقة متطلبات SIEM معتمدة                                             |

3

|               |                                                                                            |
|---------------|--------------------------------------------------------------------------------------------|
| الإجراء       | تنفيذ نشر منصة SIEM وربط المصادر اللوجستية الأساسية (جدران الحماية، الخوادم، نقاط النهاية) |
| المسؤول       | SOC Manager                                                                                |
| الإطار الزمني | الشهر 3-4                                                                                  |
| النتائج       | نشط مع تغطية مصادر أساسية موثقة SIEM                                                       |

4

|               |                                                                                                        |
|---------------|--------------------------------------------------------------------------------------------------------|
| الإجراء       | تطوير قواعد الكشف وسيناريوهات الاستجابة (Use Cases) ذات الأولوية بناء على استخبارات التهديدات الحكومية |
| المسؤول       | SOC Manager                                                                                            |
| الإطار الزمني | الشهر 5                                                                                                |
| النتائج       | مكتبة Use Cases مفصلة ومختبرة                                                                          |

5

|               |                                                                                |
|---------------|--------------------------------------------------------------------------------|
| الإجراء       | تفعيل عمليات SOC على مدار الساعة وتحديد مؤشرات الأداء الرئيسية ومراجعتها شهريا |
| المسؤول       | SOC Manager                                                                    |
| الإطار الزمني | الشهر 6                                                                        |
| النتائج       | تقرير أداء SOC الشهري الأول                                                    |

1

|               |                                                                                                      |
|---------------|------------------------------------------------------------------------------------------------------|
| الإجراء       | إجراء مراجعة شاملة للحسابات المتميزة والمستخدمين الحاليين وتصنيف مستويات الوصول وفق مبدأ أدنى صلاحية |
| المسؤول       | المسؤول أمن السيراني e Lead                                                                          |
| الإطار الزمني | الشهر 1                                                                                              |
| النتائج       | سجل حسابات معتمد مع تصنيف الصلاحيات                                                                  |

2

|               |                                                                                     |
|---------------|-------------------------------------------------------------------------------------|
| الإجراء       | نشر حل إدارة الوصول المتميز PAM وتطبيق تدوير كلمات المرور الآلي على الحسابات الحرجة |
| المسؤول       | CISO                                                                                |
| الإطار الزمني | الشهر 2-3                                                                           |
| النتائج       | حل PAM مفعل على الحسابات الحرجة                                                     |

3

|               |                                                                                                |
|---------------|------------------------------------------------------------------------------------------------|
| الإجراء       | تطبيق المصادقة متعددة العوامل MFA على جميع الحسابات الإدارية وبوابات الوصول عن بعد وفق NCA DCC |
| المسؤول       | المسؤول أمن السيراني e Lead                                                                    |
| الإطار الزمني | الشهر 3                                                                                        |
| النتائج       | مفعل على 100% من الحسابات الإدارية MFA                                                         |

4

|               |                                                                              |
|---------------|------------------------------------------------------------------------------|
| الإجراء       | تنفيذ دورة مراجعة دورية ربع سنوية لصلاحيات الوصول وإلغاء الحسابات غير النشطة |
| المسؤول       | SOC Manager                                                                  |
| الإطار الزمني | الشهر 4                                                                      |
| النتائج       | تقرير مراجعة الصلاحيات الربع سنوي                                            |

5

|               |                                                                           |
|---------------|---------------------------------------------------------------------------|
| الإجراء       | دمج حل IAM مع منصة SIEM لرصد التحكم في الوصول والتنبيه على الأنماط الشاذة |
| المسؤول       | SOC Manager                                                               |
| الإطار الزمني | الشهر 5                                                                   |
| النتائج       | تكامل IAM-SIEM موثق مع قواعد كشف فعالة                                    |

1

|               |                                                                              |
|---------------|------------------------------------------------------------------------------|
| الإجراء       | تشكيل فريق CSIRT وتحديد أدوار الأعضاء ومسؤولياتهم وقنوات التصعيد وفق NCA ECC |
| المسؤول       | CISO                                                                         |
| الإطار الزمني | الشهر 1                                                                      |
| النتائج       | ميثاق CSIRT وهيكل الأدوار معتمد                                              |

2

|               |                                                                                                  |
|---------------|--------------------------------------------------------------------------------------------------|
| الإجراء       | تطوير خطة الاستجابة للحوادث الرسمية وتضمينها تصنيف الحوادث وإجراءات الاحتواء والاستئصال والتعافي |
| المسؤول       | المسؤول أمن السيراني e Lead                                                                      |
| الإطار الزمني | الشهر 2                                                                                          |
| النتائج       | خطة الاستجابة للحوادث معتمدة                                                                     |

3

|               |                                                                                                            |
|---------------|------------------------------------------------------------------------------------------------------------|
| الإجراء       | إعداد كتب التشغيل (Playbooks) لأبرز سيناريوهات التهديد (برمجيات الفدية، التصيد الاحتيالي، اختراق البيانات) |
| المسؤول       | SOC Manager                                                                                                |
| الإطار الزمني | الشهر 3                                                                                                    |
| النتائج       | مكتبة Playbooks موثقة وجاهزة للتنفيذ                                                                       |

4

|                                                                                          |               |
|------------------------------------------------------------------------------------------|---------------|
| تنفيذ تمرين محاكاة حوادث (Tabletop Exercise) يشمل الإدارة العليا وتقييم فجوات الخطة بعده | الإجراء       |
| CISO                                                                                     | المسؤول       |
| الشهر 4                                                                                  | الإطار الزمني |
| تقرير تمرين المحاكاة وتوصيات التحسين                                                     | النتائج       |

5

|                                                                                      |               |
|--------------------------------------------------------------------------------------|---------------|
| تنفيذ قناة الإبلاغ عن الحوادث وربطها بمنظومة NCA CERT وتوثيق إجراءات الإبلاغ الخارجي | الإجراء       |
| المسؤول أمن السيراني e Lead                                                          | المسؤول       |
| الشهر 5                                                                              | الإطار الزمني |
| قناة إبلاغ مفعلة وإجراءات NCA CERT موثقة                                             | النتائج       |

1

|                                                                                        |               |
|----------------------------------------------------------------------------------------|---------------|
| تنفيذ مسح شامل للثغرات الأمنية على جميع الأصول التقنية وتصنيف النتائج وفق درجة الخطورة | الإجراء       |
| SOC Manager                                                                            | المسؤول       |
| الشهر 1                                                                                | الإطار الزمني |
| تقرير مسح الثغرات الأمنية الأولي                                                       | النتائج       |

2

|                                                                                                          |               |
|----------------------------------------------------------------------------------------------------------|---------------|
| بناء برنامج إدارة الثغرات الدوري مع تحديد جداول زمنية للمعالجة وفق أولوية الخطورة وتكامله مع NCA ECC-2-3 | الإجراء       |
| المسؤول أمن السيراني e Lead                                                                              | المسؤول       |
| الشهر 2                                                                                                  | الإطار الزمني |
| برنامج إدارة الثغرات معتمد وجدول معالجة موثق                                                             | النتائج       |

3

|                                                                                                   |               |
|---------------------------------------------------------------------------------------------------|---------------|
| حلمنع فقدان البيانات DLP على البيانات الحكومية الحساسة وتطبيق سياسات التصنيف والحماية وفق NCA DCC | الإجراء       |
| CISO                                                                                              | المسؤول       |
| الشهر 3-4                                                                                         | الإطار الزمني |
| حل DLP مفعّل مع سياسات بيانات حكومية معتمدة                                                       | النتائج       |

4

|                                                                                                      |               |
|------------------------------------------------------------------------------------------------------|---------------|
| ضوابط الوصول عن بعد الآمن (VPN مؤسسي، جلسات مشفرة، مصادقة ثنائية) ومراجعة إعدادات جدار الحماية تطبيق | الإجراء       |
| SOC Manager                                                                                          | المسؤول       |
| الشهر 4                                                                                              | الإطار الزمني |
| بنية وصول عن بعد آمنة موثقة ومختبرة                                                                  | النتائج       |

5

|                                                                                                        |         |
|--------------------------------------------------------------------------------------------------------|---------|
| إجراء اختبار الاختراق السنوي الأول من طرف ثالث مستقل ورفع التقرير النهائي مع خطة معالجة للإدارة العليا | الإجراء |
| CISO                                                                                                   | المسؤول |

|               |                                          |
|---------------|------------------------------------------|
| الإطار الزمني | الشهر 6                                  |
| النتائج       | تقرير اختبار الاختراق وخطة معالجة معتمدة |

## خارطة الطريق التنفيذية

تأسيس إدارة الأمن السيبراني وتعيين CISO .المرحلة 1: تأسيس (6-1 أشهر)

المرحلة 1: تأسيس (6-1 أشهر) :المرحلة

1-6 أشهر:الفترة

تأسيس إدارة الأمن السيبراني وتعيين CISO :المبادرة

الإدارة العليا / CISO :المسؤول

هيكل CISO ولجنة حوكمة معتمدة :المخرج المتوقع

NCA ECC :الإطار المرتبط

نشر حلول الحماية من البرمجيات الخبيثة على جميع النقاط .المرحلة 1: تأسيس (6-1 أشهر)

المرحلة 1: تأسيس (6-1 أشهر) :المرحلة

1-6 أشهر:الفترة

نشر حلول الحماية من البرمجيات الخبيثة على جميع النقاط :المبادرة

فريق العمليات :المسؤول

مخرج برنامج معتمد ومقاس :المخرج المتوقع

NCA ECC :الإطار المرتبط

تأسيس حوكمة الأمن السيبراني .المرحلة 1: تأسيس (6-1 أشهر)

المرحلة 1: تأسيس (6-1 أشهر) :المرحلة

1-6 أشهر:الفترة

تأسيس حوكمة الأمن السيبراني :المبادرة

CISO :المسؤول

هيكل حوكمة وسياسات معتمدة :المخرج المتوقع

NCA ECC :الإطار المرتبط

تأسيس CSIRT وخطط الاستجابة .المرحلة 2: تمكين وتشغيل (7-18 شهر)

المرحلة 2: تمكين وتشغيل (7-18 شهر) :المرحلة

7-18 شهر:الفترة

تأسيس CSIRT وخطط الاستجابة :المبادرة

قائد CSIRT :المسؤول

فريق CSIRT وخطط استجابة معتمدة ومختبرة :المخرج المتوقع

NCA ECC :الإطار المرتبط

برنامج إدارة الثغرات .المرحلة 2: تمكين وتشغيل (7-18 شهر)

المرحلة 2: تمكين وتشغيل (7-18 شهر) :المرحلة

7-18 شهر:الفترة

برنامج إدارة الثغرات :المبادرة

مدير الثغرات :المسؤول

برنامج ثغرات مع SLA للمعالجة :المخرج المتوقع

NCA ECC :الإطار المرتبط

تمكين وتشغيل SOC/SIEM .المرحلة 2: تمكين وتشغيل (7-18 شهر)

المرحلة 2: تمكين وتشغيل (7-18 شهر) :المرحلة

7-18 شهر:الفترة

تمكين وتشغيل SOC/SIEM :المبادرة



مدير SOC: المسؤول

تشغيلي SOC/SIEM: المخرج المتوقع

NCA ECC: الإطار المرتبط

ضبط معالجة البيانات الحساسة. المرحلة 3: تحسين واستدامة (19-24 شهر)

المرحلة 3: تحسين واستدامة (19-24 شهر): المرحلة

19-24 شهر: الفترة

ضبط معالجة البيانات الحساسة: المبادرة

مسؤول حماية البيانات: المسؤول

إجراءات معالجة بيانات حساسة معتمدة: المخرج المتوقع

NCA DCC: الإطار المرتبط

تصنيف وجرد البيانات الحساسة. المرحلة 1: تأسيس

المرحلة 1: تأسيس: المرحلة

1-6 أشهر: الفترة

تصنيف وجرد البيانات الحساسة: المبادرة

مدير حماية البيانات: المسؤول

سجل بيانات مصنفة ومعتمد: المخرج المتوقع

NCA DCC: الإطار المرتبط

تفعيل DLP ومراقبة تسرب البيانات. المرحلة 2: تمكين وتشغيل

المرحلة 2: تمكين وتشغيل: المرحلة

7-18 شهر: الفترة

تفعيل DLP ومراقبة تسرب البيانات: المبادرة

مدير حماية البيانات: المسؤول

منصة DLP وقواعد مراقبة تسرب البيانات مفعلة: المخرج المتوقع

NCA DCC: الإطار المرتبط

تطبيق ضوابط التشفير وإدارة المفاتيح. المرحلة 2: تمكين وتشغيل

المرحلة 2: تمكين وتشغيل: المرحلة

7-18 شهر: الفترة

تطبيق ضوابط التشفير وإدارة المفاتيح: المبادرة

مدير حماية البيانات: المسؤول

ضوابط تشفير وإدارة مفاتيح مطبقة: المخرج المتوقع

NCA DCC: الإطار المرتبط

## مؤشرات الأداء الرئيسية

متوسط زمن اكتشاف الحوادث الأمنية

متوسط زمن اكتشاف الحوادث الأمنية: المؤشر

KPI: النوع

> 4 ساعات: القيمة المستهدفة

CISO: المالك

شهري: الإطار الزمني

متوسط زمن الاستجابة للحوادث (MTTR)

متوسط زمن الاستجابة للحوادث (MTTR): المؤشر

KPI: النوع

> 4 ساعات: القيمة المستهدفة

CISO: المالك

شهري: الإطار الزمني

نسبة إغلاق الثغرات الحرجة ضمن SLA

نسبة إغلاق الثغرات الحرجة ضمن SLA: المؤشر

KPI: النوع

95% خلال 72 ساعة: القيمة المستهدفة

CISO: المالك

شهري: الإطار الزمني

نسبة محاولات الدخول الفاشلة الشاذة

نسبة محاولات الدخول الفاشلة الشاذة: المؤشر

KPI: النوع

100%: القيمة المستهدفة

CISO: المالك

أسبوعي: الإطار الزمني

عدد حوادث تسرب البيانات الحرجة

عدد حوادث تسرب البيانات الحرجة: المؤشر

KPI: النوع

95% أو 100% للبيانات الحساسة المصنفة: القيمة المستهدفة

CISO: المالك

شهري: الإطار الزمني

نسبة تغطية التشفير للبيانات الحساسة

نسبة تغطية التشفير للبيانات الحساسة: المؤشر

KPI: النوع

95% أو 100% للبيانات الحساسة المصنفة: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

درجة مخاطر الأطراف الثالثة

درجة مخاطر الأطراف الثالثة: المؤشر

KRI: النوع

100%: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

نسبة الأصول المصنفة وفق ضوابط البيانات

نسبة الأصول المصنفة وفق ضوابط البيانات: المؤشر

KPI: النوع

95% أو 100% للبيانات الحساسة المصنفة: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

معدل فشل اختبارات التصيد الاحتيالي

معدل فشل اختبارات التصيد الاحتيالي: المؤشر

KRI: النوع

أقل من 5%: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

نسبة انعقاد لجنة حوكمة الأمن السيبراني وفق التواتر ال معتمد

نسبة انعقاد لجنة حوكمة الأمن السيبراني وفق التواتر ال معتمد: المؤشر

KPI: النوع

100%: القيمة المستهدفة

CISO: المالك

ربع سنوي: الإطار الزمني

متوسط زمن اكتشاف الحوادث الأمنية

متوسط زمن اكتشاف الحوادث الأمنية: المؤشر

مجموع أزمنة اكتشاف الحوادث / عدد الحوادث: الصيغة

SIEM / SOC: مصدر البيانات

متوسط زمن الاستجابة للحوادث (MTTR)

متوسط زمن الاستجابة للحوادث (MTTR): المؤشر

مجموع أزمنة الاستجابة للحوادث الحرجة / عدد الحوادث الحرجة: الصيغة

ITSM / SOAR / SIEM: مصدر البيانات

نسبة إغلاق الثغرات الحرجة ضمن SLA

نسبة إغلاق الثغرات الحرجة ضمن SLA: المؤشر

(عدد الثغرات الحرجة المغلقة ضمن SLA ÷ إجمالي الثغرات الحرجة) × 100 :الصيغة  
منصة إدارة الثغرات :مصدر البيانات

نسبة محاولات الدخول الفاشلة الشاذة  
نسبة محاولات الدخول الفاشلة الشاذة :المؤشر  
(المنجز المقيس ÷ الهدف التشغيلي المعتمد) × 100 :الصيغة  
مكتب CISO / نظام الحوكمة :مصدر البيانات

عدد حوادث تسرب البيانات الحرجة  
عدد حوادث تسرب البيانات الحرجة :المؤشر  
(عدد الأصول/البيانات المشفرة / إجمالي البيانات الحساسة المصنفة) × 100 :الصيغة  
منصة تصنيف البيانات :مصدر البيانات

نسبة تغطية التشفير للبيانات الحساسة  
نسبة تغطية التشفير للبيانات الحساسة :المؤشر  
(عدد الأصول أو البيانات الحساسة المحمية بالتشفير و DLP ÷ إجمالي الأصول أو البيانات الحساسة المستهدفة) × 100 :الصيغة  
منصة التشفير / DLP / منصة تصنيف البيانات :مصدر البيانات

درجة مخاطر الأطراف الثالثة  
درجة مخاطر الأطراف الثالثة :المؤشر  
(المنجز / المخطط) × 100 :الصيغة  
مكتب CISO / نظام الحوكمة :مصدر البيانات

نسبة الأصول المصنفة وفق ضوابط البيانات  
نسبة الأصول المصنفة وفق ضوابط البيانات :المؤشر  
(عدد الضوابط المحققة ÷ إجمالي الضوابط المستهدفة) × 100 :الصيغة  
منصة الحوكمة وقياس الامتثال :مصدر البيانات

معدل فشل اختبارات التصيد الاحتيالي  
معدل فشل اختبارات التصيد الاحتيالي :المؤشر  
(عدد الموظفين الذين فشلوا في اختبار التصيد ÷ إجمالي الموظفين المختبرين) × 100 :الصيغة  
منصة محاكاة التصيد :مصدر البيانات

نسبة انعقاد لجنة حوكمة الأمن السيبراني وفق التواتر ال معتمد  
نسبة انعقاد لجنة حوكمة الأمن السيبراني وفق التواتر ال معتمد :المؤشر  
(المنجز المقيس ÷ الهدف التشغيلي المعتمد) × 100 :الصيغة  
مكتب CISO / نظام الحوكمة :مصدر البيانات

## تقييم الثقة والمخاطر

درجة الثقة: 78%

تقع المنظمة في مستوى النضج الأولي (Initial)، مما يعني غياب سياسات موثقة وقابلة للتطبيق وفق متطلبات NCA ECC و NCA DCC، وعدم اكتمال البنية التحتية لعمليات الأمن السيبراني بما فيها مركز العمليات الأمنية (SOC) وآليات الاستجابة للحوادث. تتجلى الفجوات الجوهرية في انعدام برامج إدارة الثغرات الأمنية وضعف منظومة التحكم في الوصول وإدارة الهوية، إلى جانب غياب خطط موثقة لاستمرارية الأعمال والتعافي من الكوارث المرتبطة بالحوادث السيبرانية.

اكتمال المدخلات

الوزن: 20%

الدرجة: 4

المساهمة: 15.6%

تغطية الأطر المرجعية

الوزن: 20%

الدرجة: 4

المساهمة: 15.6%

جدوى خارطة الطريق

الوزن: 20%

الدرجة: 4

المساهمة: 15.6%

جاهزية الموارد

الوزن: 15%

الدرجة: 4

المساهمة: 11.7%

نضج الحوكمة

الوزن: 15%

الدرجة: 4

المساهمة: 11.7%

جاهزية حماية البيانات

الوزن: 10%

الدرجة: 4

المساهمة: 7.8%

| 1 | الاستجابة للحوادث مما يطيل فترة الاحتواء<br>غياب سياسة مؤمنة  | عالية  | حرج | — | CISO                              |
|---|---------------------------------------------------------------|--------|-----|---|-----------------------------------|
| 2 | الثغرات الضعيفة في الأنظمة غير المحدثة<br>استغلال             | عالية  | حرج | — | مركز العمليات الأمنية SOC<br>مدير |
| 3 | التصيد الاحتمالي نتيجة ضعف الوعي<br>اختراق البيانات عبر هجمات | عالية  | عال | — | قائد حوكمة الأمن السيبراني        |
| 4 | الفدية عبر الشبكة الداخلية لغياب التجزئة<br>انتشار برمجيات    | متوسطة | حرج | — | مركز العمليات الأمنية SOC<br>مدير |
| 5 | لدى الأطراف الثالثة دون تقييم رسمي<br>مخاطر الأمن السيبراني   | متوسطة | عال | — | قائد حوكمة الأمن السيبراني        |
| 6 | الوصول يتيح امتيازات زائدة للمستخدمين<br>ضعف التحكم في        | عالية  | عال | — | وحدة إدارة الهوية والوصول<br>رئيس |

## نموذج الحوكمة والمسؤوليات

|                                                                      |                                                                           |
|----------------------------------------------------------------------|---------------------------------------------------------------------------|
| اللجنة التوجيهية للأمن السيبراني                                     | اعتماد استراتيجية الأمن السيبراني والإشراف على تنفيذها: نطاق المسؤولية    |
| مسألة عن التوجه الاستراتيجي واعتماد السياسات والميزانيات: المساءلة   | ترفع تقاريرها إلى الإدارة العليا ومجلس الإدارة: التقارير / التصعيد        |
|                                                                      | NCA ECC / NCA DCC: الإطار المرتبط                                         |
| رئيس الأمن السيبراني CISO                                            | قيادة برنامج الأمن السيبراني وإدارة المخاطر السيبرانية: نطاق المسؤولية    |
| مسألة عن تنفيذ الاستراتيجية والامتثال لـ NCA ECC و NCA DCC: المساءلة | يرفع التقارير إلى اللجنة التوجيهية والإدارة العليا: التقارير / التصعيد    |
|                                                                      | NCA ECC / NCA DCC: الإطار المرتبط                                         |
| مدير حوكمة الأمن السيبراني                                           | إدارة السياسات والمعايير ومتابعة الامتثال التنظيمي: نطاق المسؤولية        |
| مسألة عن تطوير وتحديث سياسات الأمن السيبراني: المساءلة               | يرفع التقارير إلى CISO: التقارير / التصعيد                                |
|                                                                      | NCA ECC: الإطار المرتبط                                                   |
| مدير مركز العمليات الأمنية SOC                                       | إدارة SOC والمراقبة المستمرة للتهديدات وتنفيذ SIEM: نطاق المسؤولية        |
| مسألة عن كشف الحوادث الأمنية وزمن الاستجابة الأولية: المساءلة        | يرفع التقارير إلى CISO ويصعد الحوادث الحرجة فوراً: التقارير / التصعيد     |
|                                                                      | NCA ECC: الإطار المرتبط                                                   |
| مدير حماية البيانات                                                  | إدارة DLP والتشفير وتصنيف البيانات وحمايتها: نطاق المسؤولية               |
| مسألة عن تطبيق ضوابط حماية البيانات الحساسة: المساءلة                | يرفع التقارير إلى CISO ويصعد حوادث تسرب البيانات: التقارير / التصعيد      |
|                                                                      | NCA DCC: الإطار المرتبط                                                   |
| مدير إدارة الهوية والوصول IAM/PAM                                    | إدارة الهويات والصلاحيات وتنفيذ MFA للوصول المميز: نطاق المسؤولية         |
| مسألة عن منع الوصول غير المصرح وإدارة الحسابات المميزة: المساءلة     | يرفع التقارير إلى CISO: التقارير / التصعيد                                |
|                                                                      | NCA ECC: الإطار المرتبط                                                   |
| مدير الاستجابة للحوادث CSIRT                                         | قيادة فريق CSIRT وتنفيذ خطة الاستجابة للحوادث: نطاق المسؤولية             |
| مسألة عن احتواء الحوادث وإدارتها حتى الإغلاق: المساءلة               | يرفع التقارير إلى CISO ويصعد الحوادث ذات الأثر العالي: التقارير / التصعيد |
|                                                                      | NCA ECC: الإطار المرتبط                                                   |
| مدير إدارة الثغرات                                                   | إدارة برنامج إدارة الثغرات وفحصها ومعالجتها وفق SLA: نطاق المسؤولية       |
| مسألة عن معالجة الثغرات الحرجة خلال SLA المحدد: المساءلة             | يرفع التقارير إلى CISO: التقارير / التصعيد                                |
|                                                                      | NCA ECC: الإطار المرتبط                                                   |

مدير استمرارية الأعمال / التعافي  
إدارة استمرارية الأعمال والتعافي من الكوارث السيبرانية: نطاق المسؤولية  
مسائل عن تنفيذ خطط BCP / DRP السيبرانية واختبارها: المساءلة  
يرفع التقارير إلى CISO والإدارة العليا: التقارير / التصعيد  
الإطار المرتبط: NCA ECC

مكتب إدارة المشاريع PMO  
متابعة تنفيذ خارطة الطريق والمبادرات السيبرانية: نطاق المسؤولية  
مسائل عن تتبع الإنجاز والمخاطر والتصعيد: المساءلة  
يرفع التقارير إلى CISO واللجنة التوجيهية: التقارير / التصعيد  
الإطار المرتبط: NCA ECC / NCA DCC

الإدارة العليا  
الإشراف التنفيذي ورفع المخاطر السيبرانية إلى مجلس الإدارة: نطاق المسؤولية  
مسألة عن دعم الموارد واتخاذ القرارات الاستراتيجية: المساءلة  
ترفع التقارير إلى مجلس الإدارة: التقارير / التصعيد  
الإطار المرتبط: NCA ECC / NCA DCC



## مصفوفة تتبع الأطر المرجعية

|                                                                                                              |  |
|--------------------------------------------------------------------------------------------------------------|--|
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| الفجوة   مجال القدرة   الإطار المرجعي                                                                        |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| تصنيف البيانات: مجال القدرة                                                                                  |  |
| إجراء مراجعة شاملة للحسابات المتميزة والمستخدمين الحاليين وتصنيف مستويات الوصول وفق مبدأ أدنى صلاحية: الفجوة |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| التشفير: مجال القدرة                                                                                         |  |
| ضعف ضوابط التشفير وإدارة المفاتيح: الفجوة                                                                    |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| منع تسرب البيانات / DLP: مجال القدرة                                                                         |  |
| ضعف ضوابط منع تسرب البيانات: الفجوة                                                                          |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| معالجة البيانات الحساسة: مجال القدرة                                                                         |  |
| ضعف معالجة البيانات الحساسة: الفجوة                                                                          |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| حماية البيانات: مجال القدرة                                                                                  |  |
| ضعف حماية البيانات أثناء النقل والتخزين: الفجوة                                                              |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| المخاطر   المؤشر   المبادرة   الإطار                                                                         |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| تنفيذ تصنيف البيانات / تصنيف البيانات الحساسة: المبادرة                                                      |  |
| نسبة تصنيف البيانات الحساسة: المؤشر                                                                          |  |
| اختراق البيانات أو سوء تصنيف البيانات الحساسة: المخاطر                                                       |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| تطبيق ضوابط التشفير: المبادرة                                                                                |  |
| نسبة الامتثال لسياسات التشفير: المؤشر                                                                        |  |
| تسرب البيانات أثناء النقل أو التخزين: المخاطر                                                                |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| تطبيق DLP / منع تسرب البيانات: المبادرة                                                                      |  |
| عدد حوادث تسرب البيانات أو مؤشرات منع التسرب: المؤشر                                                         |  |
| فقدان البيانات الحساسة: المخاطر                                                                              |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| معالجة البيانات الحساسة وفق الضوابط: المبادرة                                                                |  |
| نسبة الأصول الحساسة المصنفة أو المحمية: المؤشر                                                               |  |
| إفشاء غير مصرح للبيانات الحساسة: المخاطر                                                                     |  |
| NCA DCC (Data Cybersecurity Controls)                                                                        |  |
| حماية البيانات أثناء النقل والتخزين: المبادرة                                                                |  |
| نسبة الأصول المشفرة أو المحمية: المؤشر                                                                       |  |

اختراق البيانات أو ضعف حماية البيانات: المخاطر

NCA ECC (Essential Cybersecurity Controls)

NCA ECC (Essential Cybersecurity Controls)

الفجوة | مجال القدرة | الإطار المرجعي

NCA ECC (Essential Cybersecurity Controls)

حوكمة الأمن السيبراني: مجال القدرة

غياب وظيفة CISO وهيكل حوكمة الأمن السيبراني: الفجوة

NCA ECC (Essential Cybersecurity Controls)

إدارة الهوية والوصول: مجال القدرة

ضعف إدارة الهوية والوصول IAM / PAM / MFA: الفجوة

NCA ECC (Essential Cybersecurity Controls)

الرصد الأمني (SOC / SIEM): مجال القدرة

غياب مركز العمليات الأمنية SOC وأدوات SIEM: الفجوة

NCA ECC (Essential Cybersecurity Controls)

الاستجابة للحوادث: مجال القدرة

غياب فريق الاستجابة للحوادث CSIRT وخطة رسمية: الفجوة

NCA ECC (Essential Cybersecurity Controls)

إدارة الثغرات: مجال القدرة

قصور إدارة الثغرات الأمنية وغياب DLP والوصول عن بعد الآمن: الفجوة

NCA ECC (Essential Cybersecurity Controls)

NCA ECC (Essential Cybersecurity Controls)

المخاطر | المؤشر | المبادرة | الإطار

NCA ECC (Essential Cybersecurity Controls)

تأسيس إدارة الأمن السيبراني وتشكيل لجنة حوكمة الأمن السيبراني: المبادرة

نسبة اكتمال الهيكل التنظيمي والسياسات المعتمدة: المؤشر

ضعف الحوكمة أو غياب المساءلة السيبرانية: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تطبيق IAM/PAM/MFA: المبادرة

نسبة تطبيق المصادقة متعددة العوامل MFA للوصول المميز: المؤشر

اختراق أنظمة التحكم في الوصول والهوية: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تأسيس مركز العمليات الأمنية SOC وتنشيط SIEM: المبادرة

متوسط زمن كشف الحوادث الأمنية الحرجة: المؤشر

فشل آليات الكشف المبكر للتهديدات المتقدمة: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تأسيس فريق CSIRT وتطوير خطة الاستجابة للحوادث: المبادرة

متوسط زمن الاستجابة للحوادث الحرجة: المؤشر

تأخر احتواء الحوادث أو ضعف الاستجابة للحوادث: المخاطر

NCA ECC (Essential Cybersecurity Controls)

تنفيذ برنامج إدارة الثغرات الأمنية وفحص الثغرات: المبادرة

نسبة الثغرات الحرجة المعالجة خلال SLA المحدد: المؤشر

استغلال الثغرات الحرجة في الأنظمة الحكومية: المخاطر



## الملاحق

### الملحق أ — الأطر المرجعية

الأطر المرجعية المستخدمة في إعداد هذه الوثيقة:

- ECC: NCA ECC (Essential Cybersecurity Controls)
- DCC: NCA DCC (Data Cybersecurity Controls)

### الملحق ب — قاموس المصطلحات

تعريفات المصطلحات والاختصارات المستخدمة في هذه الوثيقة:

- (NCA) الضوابط الأساسية للأمن السيبراني: ECC
- (NCA) ضوابط الأمن السيبراني للبيانات: DCC
- المصادقة متعددة العوامل: MFA
- الشبكة الافتراضية الخاصة: VPN
- إدارة الهوية والوصول: IAM
- إدارة الوصول المميز: PAM
- مركز العمليات الأمنية: SOC
- إدارة المعلومات والأحداث الأمنية: SIEM
- فريق الاستجابة لحوادث الأمن السيبراني: CSIRT
- منع تسرب البيانات: DLP
- كشف التهديدات والاستجابة في النقاط الطرفية: EDR
- مؤشر المخاطر الرئيسي: KRI
- تصنيف البيانات: Data Classification
- مؤشر الأداء الرئيسي: KPI